

Produkční uživatelský test KIS

Navržené opravy a změny po prvním kritickém průchodu

Testovaný systém	https://kis.kovopraha.cz
Datum a rozsah	8. 9. 2026 · živá produkce · desktop 1280 px a mobil 390 × 844 px
Zdroj scénářů	Jednoduchý manuál produkčního testování KIS, verze 2026-09-08, 20 cest
Výsledek	NEPŘIJATO PRO PLNÝ UAT · 0 PASS · 2 FAIL · 18 BLOCKED

Závěr testera

KIS v tomto stavu nelze přijmout jako dokončený produkční UAT. Veřejná část je dostupná a základní bezpečnostní ochrany fungují, ale žádný z 20 scénářů nebylo možné uzavřít jako PASS. Osmnáct cest blokuje nesplněná vstupní brána nebo chybějící testovací přístupy a dvě veřejně ověřitelné cesty selhaly na konkrétních problémech použitelnosti a obsahu.

Největší okamžitý funkční problém je rozbitý obrázek jediného zveřejněného produktu. KIS načítá externí obrázek ze Shoptetu, zatímco vlastní Content Security Policy povoluje obrázky jen z KIS. Prohlížeč proto obrázek zablokuje na seznamu i detailu produktu.

Největší procesní problém je testovací nepřipravenost. Poslední doložený deploy je běh 32775632074 nad commitem 11f7b1fe883b16b3ccd2d35fe0f4f674fb405647, ale origin/main je cb64d0ee9c5699835e26a8d1a1c879234507c720. Bez výslovného schválení testované verze manuál zakazuje zapisovací scénáře. Přihlašovací údaje testovacích osob ani přístup k testovacímu e-mailu a bance nebyly součástí předání.

Souhrn ověřené funkčnosti

Oblast	Stav	Ověřený důkaz	Dopad
Veřejné stránky	ČÁSTEČNĚ	13 veřejných vstupů otevřeno v produkčním prohlížeči	Základní navigace a čtení fungují
E-shop	FAIL	Vyhledání produktu funguje, jeho obrázek má naturalWidth 0	Produkt působí nedůvěryhodně; mobilní karta má velkou prázdnou plochu
Testovací obsah	FAIL	Chybí TEST kroužek, lahev, velodrom, trénink a akce požadované manuálem	Navazující cesty nelze spustit
Anonymní ochrana	PASS	69 interních tras odmítlo anonymní přístup nebo skončilo na přihlášení	Nevznikl důkaz veřejného úniku interní agendy
Rodinné a dětské části	BLOCKED	Přihlašovací formuláře dostupné, přístupy nepředány	Nelze ověřit izolaci rodin, dítě ani oprávnění
Platby a e-maily	BLOCKED	Bez objednávky, banky a inboxu nelze porovnat stav	Nelze ověřit účetní ani notifikační návaznost
Mobilní zobrazení	FAIL	Bez horizontálního přetékání, ale veřejná navigace zabírá cca 175 px a ovládací prvky mají 31 až 40 px	Zbytečné rolování a slabší ovladatelnost prstem

Navržené opravy a změny

001 P0 Uzavřít bránu testované verze

Problém: Produkce a origin/main nejsou na stejném commitu a nebylo doloženo, který commit je schválený pro UAT.

Navržená změna: Zvolit jednoznačný UAT commit, nasadit jej standardním workflow nebo písemně schválit aktuálně nasazený commit. V administraci zobrazit krátký release SHA a čas deploye, aby tester nemusel používat GitHub.

Akceptace opravy: Na jedné obrazovce je vidět stejný SHA jako ve schváleném UAT záznamu; teprve poté se odblokují zápisy.

002 P0 Připravit testovací identity a provozní přístupy

Problém: Nebyla předána hesla pro Karla, Petru, Emu, Adama ani Tester Správce a tester nemá přístup do inboxu @velocota.com ani k bankovnímu ověření.

Navržená změna: Předat účty bezpečným kanálem, potvrdit jejich aktivní stav a osm pozic pracovníka. Určit osobu s přístupem do testovacího inboxu a banky. Do protokolu nepřenášet hesla, tokeny ani celé bankovní údaje.

Akceptace opravy: Pět identit se přihlásí, pracovník přepne všech osm pozic, testovací zprávy lze zkontrolovat a každou platbu lze spárovat s bankou.

003 P0 Připravit časově omezená TEST data

Problém: Na veřejných stránkách nejsou položky požadované scénáři. Kroužky, události, velodrom a tréninky jsou prázdné; TEST Klubová lahev v katalogu není.

Navržená změna: Připravit podporovaným produkčním postupem všechny položky s prefixem TEST a časovým oknem. Každá položka musí mít vlastníka, plán úklidu a vazbu na konkrétní scénář. Nepoužívat localhost seed/reset ani ostrý import.

Akceptace opravy: Veřejnost najde všechny položky z manuálu, skutečný návštěvník je bezpečně rozezná a po scénáři 20 nezůstane otevřená testovací nabídka.

004 P1 Opravit obrázky zveřejněných produktů

Problém: Jediný aktivní produkt odkazuje na cdn.myshoptet.com, ale živá CSP povoluje img-src jen self, data a blob. Obrázek je rozbitý v katalogu i detailu.

Navržená změna: Preferovaně stáhnout a validovat produktový obrázek při importu do lokálního úložiště a publikovat pouze lokální URL. Současně zobrazit při chybě skutečnou náhradní grafiku místo prázdného bloku. Pouhé rozšíření CSP o celý externí CDN host je slabší varianta.

Akceptace opravy: Každý publikovaný obrázek má naturalWidth větší než 0, detail i karta mají čitelný fallback a automatická kontrola před zveřejněním odmítne nedostupnou URL.

005 P1 Sjednotit responzivní hlavní navigaci

Problém: Úvodní stránka používá hamburger i na šířce 1280 px; po otevření vloží přibližně 400 px vysoký blok. Ostatní veřejné stránky na mobilu hamburger nemají a zobrazují trvale rozbalené menu vysoké přibližně 175 px.

Navržená změna: Použít jednu sdílenou navigaci a jeden breakpoint. Na desktopu zobrazit vodorovné menu, na mobilu kompaktní zavřené menu. Otevřený panel má být krátký, jasně seskupený a nesmí odsouvat hlavní úkol o celou obrazovku.

Akceptace opravy: Stejná navigace se chová stejně na všech veřejných stránkách při 390, 768 a 1280 px; aktivní položka je viditelná a klávesnicí dosažitelná.

006 P1 Zpřístupnit cestu k individuálním lekcím

Problém: Veřejný kalendář booking/kalendar.php je funkční, ale z hlavní stránky ani z veřejného menu na něj nevede odkaz. Stránka je navíc v navigaci označena jako Velodrom, i když obsahuje více sportovišť a individuální lekce.

Navržená změna: Přidat na hlavní stránku a do veřejného menu položku Individuální lekce. Oddělit ji od veřejných hodin velodromu a správně nastavit aktivní položku navigace a popis účelu.

Akceptace opravy: Nový návštěvník najde lekci bez znalosti URL nejvýše na dvě volby a vždy rozumí rozdílu mezi lekcí a pronájmem velodromu.

007 P1 Opravit prázdný výsledek hledání

Problém: Hledání neexistující TEST Klubové lahve zobrazí text Zatím není aktivní žádná nabídka, přestože aktivní produkt existuje. Systém zaměňuje prázdný filtr s prázdným katalogem.

Navržená změna: Rozlišit stavy Žádný produkt neodpovídá hledání a Není aktivní žádná nabídka. Zobrazit hledaný výraz, tlačítko Zrušit filtry a počet výsledků.

Akceptace opravy: Při nulovém výsledku je jasné, že katalog existuje; jedním tlačítkem se uživatel vrátí na celou nabídku.

O08 P1 Vyčistit nebo převzít veřejný termín technického účtu

Problém: Veřejný kalendář zobrazuje termín Zvedáme těžký váhy za 100 Kč pod účtem KIS testovací administrátor. Termín nemá povinný prefix TEST a působí jako opuštěný testovací záznam.

Navržená změna: Rozhodnout, zda jde o test nebo reálnou nabídku. Test skrýt a účetně uzavřít; reálnou nabídku převést na skutečného vlastníka a upravit název i popis. Zablokovat publikaci z technického účtu bez výslovného provozního vlastníka.

Akceptace opravy: Ve veřejném kalendáři nejsou anonymní technické/testovací položky bez prefixu a každá placená položka má odpovědnou osobu.

O09 P2 Zvětšit dotykové cíle a formulářová pole

Problém: Na mobilu má řada tlačítek, polí a filtrů výšku 31 až 40 px. To je pod praktickým cílem 44 px pro pohodlné ovládání prstem, zvláště pro dítě.

Navržená změna: Nastavit minimální výšku 44 px pro hlavní tlačítka, vstupy, výběry a ikonové ovladače. U registrace na úzkém telefonu skládat Jméno a Příjmení pod sebe.

Akceptace opravy: Na 390 px nemá žádný hlavní formulářový ovladač výšku pod 44 px a všechny prvky lze pohodlně použít bez přiblížení.

O10 P2 Opravit nadpisovou hierarchii kroužků

Problém: Stránka Kroužky používá dva nadpisy H1: Placené kroužky a Bezplatné kroužky. Stránce chybí jediný společný H1.

Navržená změna: Použít jeden H1 Kroužky a klubové akce a tři sekční H2 pro placené kroužky, bezplatné kroužky a placené události.

Akceptace opravy: Každá veřejná stránka má právě jeden H1 a návaznou hierarchii H2/H3.

O11 P2 Změnit slepé prázdné stavy na další krok

Problém: Kroužky, velodrom, tréninky a klubový kalendář sdělují pouze, že nic není. Uživatel neví, zda změnit měsíc, přihlásit se, vrátit se později nebo kontaktovat klub.

Navržená změna: Ke každému prázdnému stavu přidat konkrétní další krok: další dostupné období, návrat na přehled, jinou službu nebo kontakt. Nevytvářet nepravdivý příslib dostupnosti.

Akceptace opravy: Prázdná stránka vždy nabídne alespoň jednu smysluplnou cestu a vysvětlí časový rozsah, který právě zobrazuje.

O12 P2 Přidat před-UAT kontrolu a automatický důkaz

Problém: Manuál předpokládá připravené účty, nabídky, Stripe sandbox, e-mail a banku, ale tester až během průchodu zjišťuje, že chybí.

Navržená změna: Vytvořit read-only kontrolní stránku pro Tester Správce: release SHA, stav pěti identit, počet osmi pozic, existence TEST položek, Stripe test/live příznaky bez tajemství, bankovní konfigurace, fronta e-mailů a plán úklidu. Kontrola nesmí sama nic vytvářet ani odesílat.

Akceptace opravy: Před scénářem 01 je vidět jedna zelená kontrola s časem ověření; jakákoli chybějící podmínka konkrétně blokuje odpovídající scénář.

Stav dvaceti scénářů

Status vyjadřuje výsledek celého navazujícího příběhu, nikoli pouze dostupnost vstupní stránky. BLOCKED není PASS ani chyba aplikace; znamená, že nebylo bezpečné nebo možné provést požadovaný zápis.

Scénář	Stav	Co bylo ověřeno	Co musí následovat
01 Nová rodina	BLOCKED	Registrace, rodičovské přihlášení a obnova hesla jsou veřejně dostupné.	Schválit verzi, předat inbox a účet; provést registraci, ověření, odhlášení a jednorázový reset.
02 Ema do klubu	BLOCKED	Dětské přihlášení existuje; chráněné rodinné stránky bez relace přesměrují na login.	Předat rodinné, dětské a registrařské přístupy; provést vazbu a test izolace rodin.
03 Kroužek a trénink	BLOCKED	Veřejná stránka kroužků funguje, ale neobsahuje TEST nabídku.	Připravit kroužek, objednávku, bankovní platbu, soupisku a trénink.

Scénář	Stav	Co bylo ověřeno	Co musí následovat
04 Stripe sandbox	BLOCKED	Historický workflow 31848143985 potvrdil testovací pár a absenci live páru; dnešní stav na objednávce nebyl ověřen.	Ověřit aktuální test režim, vytvořit čekající objednávku a zkontrolovat webhookovou idempotenci.
05 Bezplatná akce	BLOCKED	Veřejné kroužky a události jsou prázdné.	Připravit kapacitu 1, dvě rodiny a ověřit čekací listinu i uvolnění místa.
06 Placená akce	BLOCKED	Žádná placená TEST událost není veřejně otevřena.	Připravit produkt a dokončit platbu, účast a notifikace.
07 Klubové zboží	FAIL	Katalog a hledání fungují; jediný produkt má rozbitý obrázek a TEST lahev chybí.	Opravit obrázky, připravit lahev, objednávku, sklad, stavy, storno a vratku.
08 Veřejný velodrom	BLOCKED	Stránka hlásí, že není vypsána žádná veřejná hodina.	Připravit bezplatný a placený termín a provést kapacitu, QR platbu a storno.
09 Individuální lekce	BLOCKED	Přímá stránka kalendáře funguje a ukazuje termíny; z hlavní navigace ji nelze najít.	Přidat veřejný vstup, připravit TEST lekci a provést trenérské potvrzení i čekací listinu.
10 Tréninkový den	BLOCKED	Veřejný rozvrh pro 09/2026 je prázdný.	Připravit plán a ověřit docházku, měření, fotografii, opravu a všechny role.
11 Závod	BLOCKED	Správa závodů je anonymně chráněná.	Přihlásit vedoucího, rodiče a dítě; založit a opravit TEST výsledek a přílohu.
12 Zátěžový test	BLOCKED	Citlivé formuláře a přehledy jsou anonymně chráněné.	Připravit bezpečné soubory a ověřit veřejnou versus interní část přes tři role.
13 Členský příspěvek	BLOCKED	Finanční a rodinné části nejsou anonymně dostupné.	Předat banku a inbox; provést předpis, připomínku a skutečných 10 Kč.
14 Týdenní souhrn	BLOCKED	Fronta i rodinné souhrny jsou anonymně chráněné.	Připravit týdenní data, odběr a jedno skutečné doručení; ověřit vypnutí.
15 Člen a soupiska	BLOCKED	Všechny registrářské trasy jsou anonymně chráněné.	Přihlásit role, provést náhled importu, přesun a audit bez duplicitní identity.
16 Výkazy a kredity	BLOCKED	Výkazy, sazby a kredity jsou anonymně chráněné.	Navázat na scénář 10 a ověřit oddělení trenéra, vedoucího a financí.
17 Provoz klubu	BLOCKED	Adresáře příloh neumožňují výpis; konkrétní soubor nebyl k dispozici pro přímý test.	Připravit syntetický doklad a ověřit jízdu, servis, vyúčtování i autorizovaný download.
18 Osm pozic	BLOCKED	69 interních tras odmítá anonymní přístup nebo vyžaduje přihlášení.	Předat Tester Správce a projít osm aktivních kontextů, cizí role, audit a deaktivaci.
19 Veřejnost a dítě	FAIL	Veřejné vstupy jsou čitelné a bez horizontálního přetečení, ale požadované TEST položky nelze najít; dětská část nemá přístup.	Opravit navigaci a obsah; poté provést skutečné pozorování osmiletého dítěte bez nápovědy.
20 Úklid	BLOCKED	Nevznikla nová testovací data; veřejný technický termín vyžaduje rozhodnutí vlastníka.	Po plném UAT doložit uzavření nabídek, účtů, fronty, plateb a vratek bez mazání auditu.

Pozitivní kontroly

- HTTP adresa přesměruje jedním krokem na HTTPS; odpověď obsahuje HSTS, nosniff, SAMEORIGIN a omezení oprávnění pro kameru, mikrofon a polohu.
- Session cookie je Secure, HttpOnly a SameSite=Lax. Veřejné HTML odpovědi používají no-store/no-cache.
- Veřejný ICS endpoint vrací text/calendar a syntakticky platný prázdný VCALENDAR.
- Vyhledání existujícího produktu podle slova bunda funguje a neplatný produktový odkaz vrátí srozumitelnou 404 stránku.
- Na šířce 390 px nebylo u kontrolovaných veřejných stránek zjištěno horizontální přetékaní.
- Viditelné formulářové prvky mají přiřazené textové popisky a klávesová navigace hlavní stránky postupuje v logickém pořadí.
- Dříve rizikové veřejné vstupy pub.php, přehled skupin a podskupin už neposkytují anonymně interní obsah; přesměrují na veřejný rozvrh nebo přihlášení.

Podmínky opakovaného testu

Pořadí	Podmínka	Důkaz před pokračováním
1	Schválit a označit testovaný release	SHA v produkci odpovídá UAT schválení
2	Nasadit opravy O04 až O08	Obrázky, navigace, hledání a veřejný obsah projdou rychlým smoke testem
3	Bezpečně předat pět identit	Přihlášení všech rolí bez sdílení hesel v protokolu
4	Připravit TEST nabídky a úklid	Každý scénář má viditelnou položku, vlastníka a konec platnosti
5	Potvrdit e-mail, banku a Stripe	Inbox, bankovní porovnání a aktuální testovací Stripe stav jsou dostupné
6	Projít scénáře 01 až 20 v pořadí	U každého stavu je důkaz před a po akci, příjemce zprávy a kontrola duplicity
7	Provést bezpečný úklid	Nula otevřených TEST nabídek a aktivních testovacích účtů; audit a finance zůstávají

Rozsah a omezení tohoto průchodu

Test proběhl proti živému webu, nikoli proti lokální kopii. Byly provedeny pouze read-only a bezpečné navigační akce. Nebyl vytvořen účet, odeslán e-mail, nahrán soubor, vytvořena objednávka, provedena platba, změněno oprávnění ani spuštěn deploy. Bez přístupů nebylo možné ověřit izolaci dvou rodin, dětský účet, přepínání osmi pozic, bankovní párování, Stripe webhook, e-mailovou frontu, přílohy ani úklid.

Role osmiletého dítěte byla posouzena pouze heuristicky. Skutečná srozumitelnost pro dítě musí být ověřena pozorováním reálného osmiletého testera bez nápovědy rodiče, jak požaduje scénář 19.